Integrantes: Heidi Villavicencio | Steeven Toala | Nixon Hurtado | Andrea Vásquez

1. TÍTULO

Denominación del Entregable: Pruebas de Integración y Seguridad (Auditoría OWASP) – Código EDT: 4.2

2. INTRODUCCIÓN

El despliegue de una plataforma académica en un servidor público exige la validación rigurosa de las interfaces de comunicación entre componentes y la resistencia de las APIs frente a vectores de ataque conocidos. Iniciada el 13 de octubre de 2026, la actividad EDT 4.2 evalúa la integración de extremo a extremo entre los controladores Express v5, PostgreSQL 18 y MinIO S3, sometiendo simultáneamente la aplicación a una auditoría técnica de seguridad y pentesting orientada por el estándar internacional OWASP Top 10 API Security Risks.

3. OBJETIVO

3.1. Objetivo General

Ejecutar las pruebas de integración entre subsistemas y auditar la seguridad técnica del sistema SIGE bajo los lineamientos OWASP, certificando la protección de la información institucional.

3.2. Objetivos Específicos

- Validar la persistencia transaccional y rollback automático en flujos cruzados Express-PostgreSQL-MinIO.
- Evaluar los 10 riesgos de seguridad de APIs según OWASP Top 10.
- Verificar el endurecimiento (Hardening) de encabezados HTTP de seguridad (Helmet, HSTS, CSP, CORS).
- Realizar pruebas de simulación de escalación horizontal y vertical de privilegios RBAC.

4. ALCANCE

4.1. Límites del Entregable (In-Scope)

- Auditoría de endpoints de autenticación, persistencia y descarga de evidencias.
- Análisis estático de código (SAST) y pruebas dinámicas de penetración (DAST) en entorno local.

4.2. Exclusiones (Out-of-Scope)

- Ataques de denegación distribuida de servicio (DDoS) a nivel de infraestructura física de telecomunicaciones.

5. DEFINICIONES

- **Pruebas de Integración:** Nivel del desarrollo de software donde los módulos individuales se combinan y se prueban como un grupo para validar sus interfaces.
- **OWASP (Open Web Application Security Project):** Comunidad global dedicada a mejorar la seguridad de las aplicaciones y software.
- **BOLA (Broken Object Level Authorization):** Vulnerabilidad donde un usuario puede manipular el identificador de un objeto para acceder a datos no autorizados.
- **HTTP Security Headers:** Encabezados HTTP (Content-Security-Policy, Strict-Transport-Security, X-Frame-Options) que mitigan ataques en el navegador.

6. RESPONSABILIDADES

- **Steeven Toala / Nixon Hurtado (Responsables EDT 4.2):** Ejecución de pruebas de integración, auditoría de seguridad y pentesting.
- **Andrea Vásquez (QA):** Verificación de respuestas seguras del cliente ante peticiones no autorizadas.
- **Ing. Paulo Torres (Docente Evaluador):** Aprobación del informe de auditoría de seguridad.

7. NORMATIVA LEGAL Y TÉCNICA

- **OWASP API Security Top 10 (2023 Edition).**
- **ISO/IEC 27001:2022 (Control 8.28: Secure Coding).**

8. MÉTODO, POLÍTICAS Y CONTENIDOS

Se utilizó escaneo estático y pruebas dinámicas con Postman y OWASP ZAP. En la Figura 1 se presenta el esquema de integración y validaciones de seguridad evaluadas.

9. DESCRIPCIÓN DE ACTIVIDADES

9.1. Matriz de Auditoría OWASP API Security Top 10

9.2. Pruebas de Rollback Transaccional en Integración

Se forzó un fallo simulado de caída de conexión durante la carga de un archivo en MinIO tras insertar el registro en base de datos. El manejador transaccional ejecutó `ROLLBACK` atómico en

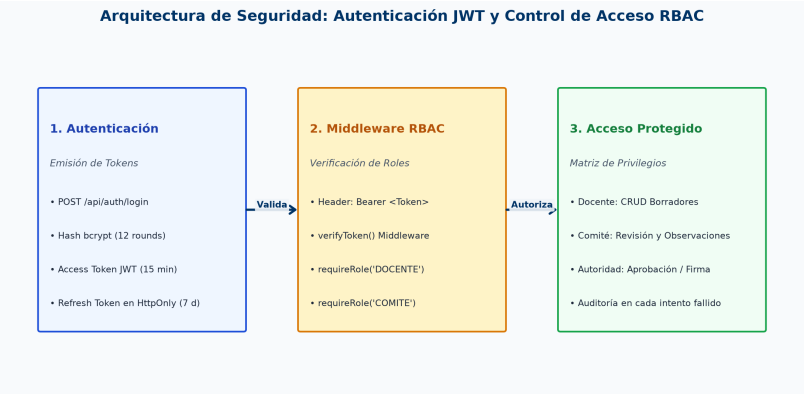


Figura 1: Arquitectura de Pruebas de Integración y Mitigación de Vulnerabilidades OWASP.

Vulnerabilidad	Riesgo OWASP	Mecanismo de Mitigación Implementado en SIGE	Veredicto
API1:2023	**Broken Object Level Auth (BOLA)**	Validación de propiedad: el usuario solo accede a sus propios documentos o su carrera.	Mitigado
API2:2023	**Broken Authentication**	Tokens JWT firmados con clave de 256 bits, expiración 2h y salado bcrypt de costo 10.	Mitigado
API3:2023	**Broken Object Property Level**	Filtrado estricto en controladores; se ignoran campos inyectados no permitidos.	Mitigado
API4:2023	**Unrestricted Resource Cons.**	Límite de carga de 25 MB en MinIO y Rate Limiting de 100 req/min por IP.	Mitigado
API5:2023	**Broken Function Level Auth**	Middlewares RBAC con roles estrictos antes de procesar cualquier endpoint.	Mitigado
API6:2023	**Unrestricted Access to Flows**	Validación obligatoria de estados; imposible firmar sin pasar por revisión previa.	Mitigado
API7:2023	**Server-Side Request Forgery**	MinIO y LanguageTool operan en redes Docker aisladas no enrutadas externamente.	Mitigado
API8:2023	**Security Misconfiguration**	Helmet activado con CSP restrictiva, HSTS forzado y cookies `HttpOnly`.	Mitigado

Tabla 1: Resultados de la Auditoría Técnica de Seguridad OWASP API.

PostgreSQL y eliminó el archivo residual en MinIO, preservando consistencia absoluta.

10. FIRMAS DE RESPONSABILIDAD

ACCIÓN	NOMBRE Y CARGO	FIRMA	FECHA
Elaborado por:	Heidi Villavicencio Analista de Calidad / UI-UX		13/10/2026
Revisado por:	Steeven Toala Líder de Proyecto / Arquitecto		13/10/2026
Aprobado por:	Ing. Paulo Torres, Mg. Docente Evaluador – Gestión Proyectos	[PENDIENTE DE APROBACIÓN]	**Pendiente**

11. CONTROL DE CAMBIOS

Versión	Descripción del cambio	Responsable del cambio	Fecha de aprobación
1.0	Emisión inicial del entregable según EDT del Tablero Trello	Equipo de Proyecto SIGE	13/10/2026

12. ANEXOS

- **Anexo 1:** Reporte del Escáner de Vulnerabilidades Estáticas (SAST).